

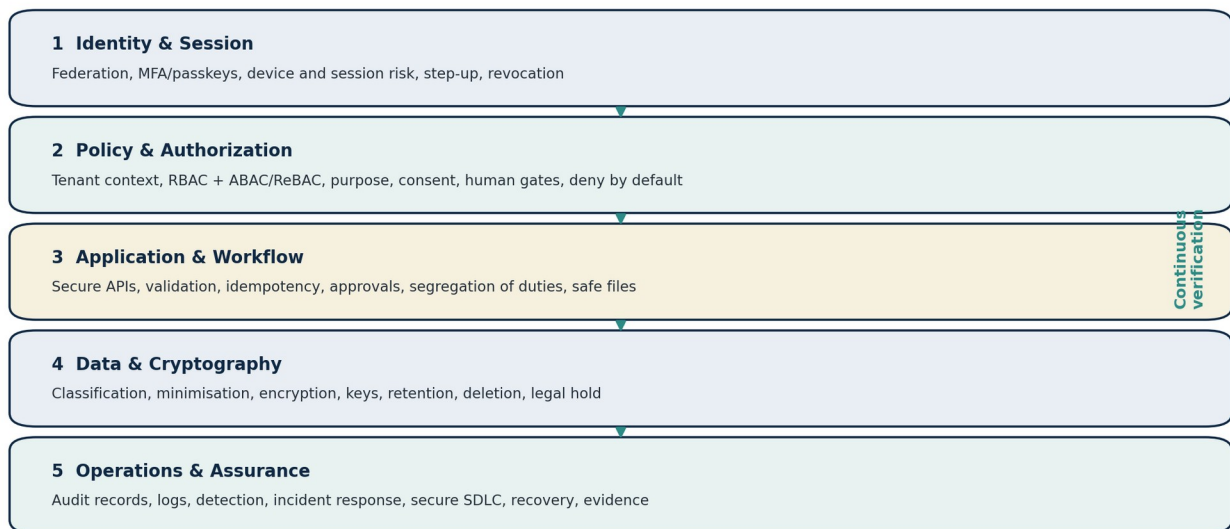
Sicherheit, Datenschutz, Rechte & Auditierbarkeit

Verbindliche Schutzarchitektur für Identitäten, Mandanten, Policies, Daten, Dateien, Support, Audit Records, Secure SDLC, Incident Response und Privacy by Design.

Deny by default. Explainable access. Verifiable evidence. Controlled lifecycle.

Security & Privacy Architecture

Defense in depth: every layer enforces identity, tenant, purpose, data and evidence rules.



ARBEITSBEZEICHNUNG ISMS Managed Service Platform

VERSION 1.0

STATUS Erstellt

STAND 22.07.2026

ABHÄNGIGKEITEN Dokument 00 bis 18

Dokumentauftrag & Verbindlichkeit

Dokument 19 ist die kanonische Quelle für Security Architecture, Threat Model, Identity, RBAC/ABAC/ReBAC, Tenant Isolation, privilegierte und Supportzugriffe, Kryptografie, Key- und Secret-Management, Datenschutz-Lifecycle, Retention, Canonical Audit Records, Logging, File- und Export Security, Secure SDLC, Supply Chain, Vulnerability Management und Incident Response. Dokument 20A bis 20C konkretisieren KI, Agenten und Umsetzung, dürfen diese Schutzgrenzen aber nicht still umgehen.

Steuerungsfeld	Festlegung
Dokument-ID	19
Status	Erstellt – Version 1.0
Owner	Product Security Owner / Privacy Owner
Gültigkeit	Bis zur freigegebenen Nachfolgeversion
Datenstatus	Alle Unternehmen, Identitäten, Incidents, Evidence- und Security-Ereignisse des Demonstrators sind synthetisch.
Änderungskontrolle	Änderungen an Identity, Authorization, Tenant Isolation, Support, Kryptografie, Retention, Audit, Logging, File-/Exportpfaden, Secure-SDLC-Gates oder Incident Response benötigen Security-/Privacy-Impactanalyse, Tests und Freigabe.

Inhalt

1 Auftrag · 2 Summary · 3 Verfassung · 4 Schutzgüter · 5 Threat Model · 6 Klassifikation · 7–9 Identity, Authentisierung & Sessions · 10 Autorisierung · 11 Tenant Isolation · 12–14 Privileged, Support & Workload Access · 15–17 Kryptografie, Keys & Secrets · 18–23 Datenschutz und Datenlebenszyklus · 24–26 Audit, Logging & Evidence · 27–30 App, Browser, Files & Integrationen · 31–33 Secure SDLC, Supply Chain & Tests · 34–36 Incident, Breach & Recovery · 37–40 Governance, Shared Responsibility, Control Center & Demo · 41–50 Szenarien, Mappings, Akzeptanz, Entscheidungen, Quellen und Änderungen

1. Auftrag und Abgrenzung

Dokument 19 ist die kanonische Sicherheits-, Datenschutz-, Berechtigungs- und Auditierbarkeitsquelle für die ISMS Managed Service Platform. Es konkretisiert die in Dokument 18 gesetzten Architekturgrenzen und legt fest, wie Identitäten, Mandanten, Daten, Dateien, APIs, Integrationen, privilegierte Tätigkeiten, Supportzugriffe, Audit Records, technische Logs, Sicherheitsereignisse und Datenschutzanforderungen geschützt und nachweisbar beherrscht werden.

Das Dokument beantwortet insbesondere:

- Welche Schutzgüter, Angreifer, Trust Boundaries und Missbrauchsfälle sind für die Plattform maßgeblich?
- Wie werden Nutzer, Service Accounts, Agenten, Connectoren und Supportpersonen sicher identifiziert?
- Wie kombiniert die Plattform RBAC, ABAC und beziehungsbezogene Regeln, ohne Berechtigungen unverständlich zu machen?
- Wie wird verhindert, dass Portfoliofunktionen, Suche, Reports, Graphpfade oder Fehlertexte Informationen zwischen Mandanten offenlegen?
- Wie funktionieren privilegierte Administration, zeitlich begrenzter Supportzugriff und Break Glass?
- Wie werden Daten klassifiziert, minimiert, verschlüsselt, aufbewahrt, exportiert und nachweisbar gelöscht?
- Welche fachlichen Audit Records müssen manipulationsgeschützt, vollständig und langfristig prüfbar bleiben?
- Wie unterscheiden sich fachliche Audit Records, technische Logs, Security Events und Evidence Artefacts?
- Welche Sicherheitsanforderungen gelten für Browser, APIs, Dateien, Reports, Integrationen und Automationen?
- Wie werden sichere Softwareentwicklung, Lieferkette, Schwachstellenmanagement, Tests und Incident Response organisiert?
- Welche Sicherheitsfunktionen müssen im privaten Demonstrator real funktionieren, obwohl ausschließlich synthetische Unternehmensdaten verwendet werden?

Nicht Gegenstand dieses Dokuments sind die fachliche ISMS-Methodik aus Dokument 08 und 09, die vollständige technische Laufzeitarchitektur aus Dokument 18, die konkrete KI-Sicherheitsarchitektur aus Dokument 20A, die Verantwortungsverteilung der virtuellen Agentenfirma aus Dokument 20B oder der repositoryzentrierte Entwicklungsbetrieb aus Dokument 20C. Dokument 19 definiert jedoch verbindliche Security Gates, die diese Nachfolger nicht umgehen dürfen.

2. Executive Summary

Die Plattform verarbeitet hochsensible Informationen über Unternehmensstrukturen, Risiken, Schwachstellen, Controls, Entscheidungen, Audits, Personen, Lieferanten und Managed Services. Ihr Sicherheitsmodell darf deshalb nicht auf einer einzelnen Login-Rolle oder einer Netzwerkgrenze beruhen. Es folgt einem **Defense-in-Depth- und Zero-Trust-Prinzip**: Jeder Zugriff wird anhand von Identität, Mandant, Objekt, Beziehung, Zweck, Sensitivität, Sessionrisiko, Delegation und gegebenenfalls menschlicher Freigabe serverseitig bewertet.

Die Sicherheitsarchitektur kombiniert:

- föderierte Enterprise-Identitäten über OIDC oder SAML,
- phishingresistente MFA oder Passkeys für privilegierte und kritische Tätigkeiten,
- kurzlebige Sessions mit kontrollierter Erneuerung und Widerruf,
- tenantgebundene RBAC-Rollen als verständliche Basis,
- ABAC-Regeln für Datenklasse, Region, Service, Budget, Risikoschwelle und Zweck,
- beziehungsbezogene Regeln für Owner, Reviewer, Auditor, Mandat und Work Item,
- Step-up Authentication und Freigaben für Exporte, Risikoakzeptanzen, Break Glass und Schlüsselaktionen,
- mehrschichtige Mandantenisolation in Anwendung, Datenbank, Queue, Storage, Search, Reporting und Observability,
- Datenklassifikation und Privacy by Design über den vollständigen Lifecycle,
- Verschlüsselung in Transit und at Rest sowie versioniertes Key Management,
- getrennte fachliche Audit Records und technische Logs,
- manipulationsgeschützte Audit- und Evidence-Ketten,
- sichere Datei-, Report- und Exportprozesse,
- secure-by-default Integrationen und Egress-Kontrollen,
- Secure SDLC, Software-Supply-Chain-Kontrollen und wiederholbare Security Tests,
- integrierte Incident Response, Kundenkommunikation und Recovery.

Die Plattform verwendet **Deny by Default**. Fehlt Tenant Context, Policy, Zweck, Owner oder Freigabe, wird die Operation nicht „best effort“ ausgeführt, sondern abgelehnt oder in einen kontrollierten Klärungszustand überführt. Ein erfolgreicher Zugriff ist keine dauerhafte Berechtigung: Session-, Identitäts-, Rollen- oder Risikosignale können eine erneute Bewertung, Step-up oder sofortige Sperrung auslösen.

Datenschutz wird als Datenarchitektur umgesetzt. Jede relevante Datenklasse besitzt Zweck, Herkunft, Owner, Rechts-/Vertragsbezug, Region, Aufbewahrung, Exportfähigkeit, Löschregel und Schutzbedarf. Die Plattform erhebt nicht automatisch vollständige Personaldaten aus Quellsystemen, wenn Rollenreferenz oder pseudonyme Identität ausreicht. Mandantenübergreifende Benchmarks verwenden nur freigegebene, aggregierte und hinreichend anonymisierte Daten; Rohdaten werden nicht in einen allgemeinen Practice-Pool kopiert.

Auditierbarkeit besitzt drei getrennte Ebenen:

1. **Canonical Audit Records** belegen fachlich relevante Zustandsänderungen, Freigaben, Entscheidungen und privilegierte Zugriffe.
2. **Technical Logs** unterstützen Diagnose, Detection und Betrieb, haben aber eine begrenztere Retention und dürfen keine Geheimnisse enthalten.
3. **Evidence Artefacts** belegen die tatsächliche Umsetzung oder Wirksamkeit eines Controls und bleiben mit Quelle, Hash, Version, Gültigkeit und Freigabe verbunden.

Der private Demonstrator implementiert echte Authentisierung, mehrere Rollen, Mandantenkontext, serverseitige Autorisierung, Audit Records, sichere Datei- und Exportpfade, synthetische Incident-Szenarien und sichtbare Trust Indicators. Er darf Mock-Identity-Provider und simulierte Scanner verwenden, aber keine zentrale Sicherheitsentscheidung lediglich im Frontend vortäuschen.

Security & Privacy Architecture

Defense in depth: every layer enforces identity, tenant, purpose, data and evidence rules.

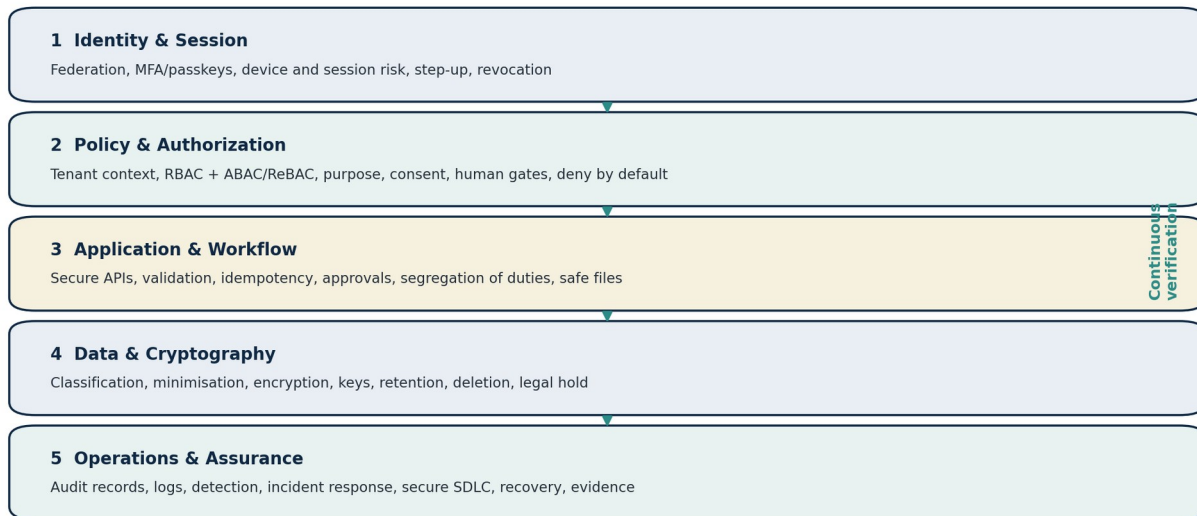


Abbildung 1: Die Security- und Privacy-Architektur erzwingt Identität, Policy, sichere Anwendung, Datenkontrollen und Assurance als zusammenhängende Schutzschichten.

3. Sicherheits- und Datenschutzverfassung

3.1 Verbindliche Prinzipien

- SP01 – Deny by Default:** Ohne explizit zulässige Policy wird Zugriff verweigert. Fehler, Timeouts oder fehlende Attribute führen nicht zu einer stillen Freigabe.
- SP02 – Server-side Enforcement:** Navigation und UI verbergen Unzulässiges, aber jede fachliche Operation wird zusätzlich im Backend und soweit sinnvoll in der Datenhaltung erzwungen.
- SP03 – Tenant First:** Jeder Request, Job, Event, Dateiobjektpfad, Search Query, Report und Audit Record trägt einen validierten Tenant Context.
- SP04 – Least Privilege:** Rechte werden auf minimale Aktion, Objektmenge, Zweck und Zeit begrenzt. Read-only ist für Integrationen und Support der Standard.
- SP05 – No Standing Privilege:** Hochprivilegierte Plattform-, Support- und Schlüsselrechte werden soweit möglich zeitlich aktiviert statt dauerhaft vergeben.
- SP06 – Separation of Duties:** Risikoakzeptanz, kritische Freigabe, Schlüsselverwaltung, Auditverifikation und produktive Veröffentlichung dürfen nicht von derselben unkontrollierten Identität allein durchgeführt werden.
- SP07 – Explicit Purpose:** Sensible Zugriffe und Exporte besitzen einen dokumentierten Zweck. „Weil die Rolle es kann“ reicht bei hochsensiblen Daten nicht aus.
- SP08 – Data Minimisation:** Import, Speicherung, Telemetrie, Reporting und KI-Kontext werden auf erforderliche Attribute begrenzt.
- SP09 – Privacy by Design and Default:** Die datenschutzfreundlichste praktikable Konfiguration ist Standard; zusätzliche Freigaben erweitern den Umfang sichtbar.
- SP10 – Strong Authentication:** Privilegierte, externe und kritische Tätigkeiten benötigen MFA; phishingresistente Verfahren werden bevorzugt.
- SP11 – Continuous Verification:** Kritische Sessions werden bei Identitäts-, Geräte-, Risiko- oder Rollenänderungen neu bewertet und gegebenenfalls widerrufen.
- SP12 – Cryptographic Agility:** Algorithmen, Schlüsseltypen und Zertifikate sind versioniert, rotierbar und nicht hart in Fachlogik eingebaut.
- SP13 – Immutable Intent:** Fachzustandsänderung und Auditabsicht werden atomar gespeichert; Auditlücken gelten als Sicherheitsfehler.
- SP14 – Explainable Authorization:** Eine Ablehnung oder Freigabe kann mit Policyversion und relevanten Attributen erklärt werden, ohne vertrauliche Details preiszugeben.
- SP15 – Secure Failure:** Bei Ausfall von Identity, Policy, Malware Scan, Key Service oder Auditpfad wird der riskante Pfad gestoppt oder kontrolliert degradiert.
- SP16 – Human Authority:** KI, Automation und Agenten dürfen keine kritische Risikoakzeptanz, Datenfreigabe, Löschung, Break-Glass-Aktivierung oder Produktivfreigabe autonom finalisieren.
- SP17 – Evidence over Assertion:** Sicherheitsstatus wird durch prüfbare Evidenz und Tests belegt, nicht nur durch Konfigurationsbehauptungen.
- SP18 – Customer Visibility:** Kunden können relevante Zugriffe, Supportaktivitäten, Exporte, Subprozessoren, Datenregionen und Sicherheitsereignisse nachvollziehen.
- SP19 – Safe Demonstration:** Demo- und Testdaten bleiben synthetisch; Demoerleichterungen sind technisch von Produktion getrennt.
- SP20 – Security as Code:** Policies, Baselines, Scans, Infrastrukturregeln, Retention und Quality Gates werden soweit sinnvoll versioniert und automatisiert geprüft.

3.2 Bewusst ausgeschlossene Muster

- universelle Super-Admin-Konten für den Alltagsbetrieb,
- Tenant-Auswahl aus einem unvalidierten Browserparameter,
- Berechtigungsprüfung ausschließlich über Frontend-Menüs,
- dauerhaft gültige persönliche API Tokens ohne Scope und Rotation,
- geteilte Connector Credentials über mehrere Mandanten,
- unprotokollierter Supportzugriff auf Kundendaten,
- Export vollständiger Datenräume ohne Zweck, Step-up und Audit,
- Speicherung von Passwörtern, Access Tokens oder privaten Schlüsseln in Logs,

- personenbezogene Leistungsüberwachung ohne klaren Zweck und Governance,
- „Anonymisierung“ durch bloßes Entfernen des Firmennamens,
- Löschung ohne Prüfung von Legal Hold, Abhängigkeiten und Backups,
- veränderbare Audit Trails ohne unabhängigen Integritätsnachweis,
- produktive Secrets oder Kundenartefakte in GitHub, Prompt, Demo Fixture oder Test Snapshot,
- automatische Freigabe kritischer KI-Empfehlungen,
- Security Tests ausschließlich kurz vor dem Go-live,
- Abhängigkeit von einem einzelnen Scanner oder einem einzelnen Compliance-Label.

4. Schutzgüter, Schutzziele und Sicherheitsdomänen

4.1 Primäre Schutzgüter

Schutzgut	Beispiele	Besondere Auswirkung bei Verlust
Mandanten- und Unternehmensdaten	Twin, Scope, Assets, Prozesse, Lieferanten	strategische Offenlegung, Wettbewerbs- und Sicherheitsrisiko
Risiko- und Schwachstellendaten	Szenarien, Findings, Bedrohungssignale	direkte Angriffsunterstützung, Fehlentscheidungen
Evidence und Auditunterlagen	Screenshots, Reports, Policies, Testnachweise	Verlust von Nachweisfähigkeit oder Manipulation von Prüfungen
Identitäten und Berechtigungen	Memberships, Delegationen, Service Accounts	unauthorisierter Zugriff, Cross-Tenant-Leak
Managemententscheidungen	Risikoakzeptanz, Budget, Freigaben	Haftungs-, Governance- und Vertrauensschaden
Managed-Service-Daten	Charter, SLA, Delivery, Eskalationen	Vertrags- und Leistungsschaden
Integrations- und Schlüsselmaterial	Client Secrets, Zertifikate, Tokens	Kompromittierung externer Systeme
Reports und Exporte	PPTX, PDF, Evidence Packages	unkontrollierte Weitergabe, falsche Aussagen
Plattform- und Betriebsdaten	Konfiguration, Logs, Backups, Telemetrie	Ausfall, Missbrauch, erschwerte Aufklärung
Quellcode und Lieferkette	Repository, Actions, Dependencies, Artefakte	Supply-Chain-Kompromittierung

4.2 Schutzziele

Die Plattform schützt Vertraulichkeit, Integrität, Verfügbarkeit, Authentizität, Nachvollziehbarkeit, Datenminimierung und kontrollierbare Verarbeitung. Für Entscheidungen und Evidenzen kommt **Nichtabstreitbarkeit im praktischen Governance-Sinn** hinzu: Die Plattform muss plausibel belegen können, welche Identität mit welcher Assurance, Policyversion und Freigabekette gehandelt hat. Eine rechtlich qualifizierte elektronische Signatur wird dadurch nicht automatisch ersetzt.

4.3 Sicherheitsdomänen

- Identity and Session Security,
- Tenant and Authorization Security,
- Data and Privacy Protection,
- Application and API Security,
- Integration and Automation Security,
- File, Evidence and Reporting Security,
- Platform and Infrastructure Security,
- Audit, Detection and Incident Response,
- Secure Development and Supply Chain,
- Governance, Assurance and Customer Trust.

5. Trust Boundaries und Threat Model

5.1 Trust Boundaries

Grenze	Vertrauensannahme	erforderliche Kontrolle
Browser ↔ Edge/API	Browser und Netzwerk sind nicht vertrauenswürdig	TLS, sichere Cookies, CSRF-/XSS-Schutz, serverseitige Policy
Identity Provider ↔ Plattform	signierte Tokens sind nur nach vollständiger Validierung vertrauenswürdig	Issuer, Audience, Nonce, PKCE, Key Rotation, Zeitprüfung
Mandant A ↔ Mandant B	keine implizite Daten- oder Metadaten-sichtbarkeit	Tenant Context, RLS, Storage- und Search-Isolation, Tests
Plattform ↔ Connector	externes System und Payload können fehlerhaft oder kompromittiert sein	Least Scope, Staging, Schema, Validation, Rate Limit, Reconciliation
App/API ↔ Worker	Jobs können wiederholt, verspätet oder manipuliert eintreffen	signierter Jobkontext, Idempotenz, Queue ACL, Checkpoint
Anwendung ↔ Datenbank/Storage	Datenbankkonto ist kein Freibrief für beliebige Tenantdaten	getrennte Rollen, RLS, objektbezogene Pfade, Encryption

Grenze	Vertrauensannahme	erforderliche Kontrolle
Betreiber ↔ Kundenmandant	Betreiberpersonal benötigt keinen Standarddatenzugriff	Just-in-Time Support, Freigabe, Masking, Audit, Kundensicht
CI/CD ↔ Produktion	Buildsystem ist hochkritische Lieferkettengrenze	OIDC Workload Identity, signierte Artefakte, Branch Protection, Reviews
Report/Export ↔ Empfänger	exportierte Daten verlassen Plattformkontrollen	Klassifikation, Wasserzeichen, Ablauf, Freigabe, Download Audit
Backup ↔ Wiederherstellung	Backup kann veraltet, kompromittiert oder cross-tenant sein	Verschlüsselung, Restore-Test, Tenantselektion, Integritätsprüfung

5.2 Angreifermodelle

- externer Angreifer ohne Konto,
- kompromittierter regulärer Nutzer,
- böswilliger oder fahrlässiger Mandantenadministrator,
- kompromittierter Berater mit Zugriff auf mehrere Kunden,
- Insider beim Plattformbetreiber,
- kompromittierter Supportaccount,
- gestohlene Session oder OAuth Token,
- kompromittierter Connector oder externer Lieferant,
- manipulierte Datei, Evidence oder Reportvorlage,
- Supply-Chain-Angreifer in Dependency, CI/CD oder Buildartefakt,
- fehlerhafte Automation oder KI-Ausgabe,
- DoS- oder Ressourcenverbrauchsangriff,
- unbeabsichtigte Offenlegung durch Suche, Logs, Caches oder Fehlermeldungen.

5.3 Kritische Abuse Cases

- Ein Berater wechselt den aktiven Kunden, während ein alter Browser-Tab noch einen Request sendet.
- Eine globale Suche verrät Objektbezeichnungen eines anderen Mandanten.
- Ein PDF-Export enthält ausgeblendete Notizen oder Daten aus einem früheren Templatezustand.
- Ein Supportmitarbeiter nutzt eine generische Adminrolle ohne Ticket und Kundenfreigabe.
- Ein Connector importiert dieselbe externe Benutzer-ID in zwei Mandanten und überschreibt Zuordnungen.
- Eine Evidence-Datei enthält Malware, aktive Inhalte oder sensible Metadaten.
- Ein Workflow führt nach Rollenentzug einen bereits geplanten kritischen Schritt weiter aus.
- Ein gelöscht Objekt erscheint weiterhin in Search Index, Cache, Report Snapshot oder Backup.
- Ein technischer Logeintrag enthält Access Token, Prompt, Evidence-Inhalt oder personenbezogene Details.
- Eine KI-Zusammenfassung erfindet eine Freigabe oder verschweigt eine Datenlücke.

Threat Models werden pro Modul und kritischer Journey aktualisiert. Neue Trust Boundaries, Datenklassen, privilegierte Pfade oder externe Schreibzugriffe benötigen eine Threat-Model-Änderung vor Produktivfreigabe.

6. Datenklassifikation und Schutzprofile

6.1 Kanonische Klassen

Klasse	Beispiele	Standardkontrollen
Public	veröffentlichte Produktinformation, öffentliche Frameworkreferenz	Integrität, Versionskontrolle
Internal	interne Methodik, neutrale Vorlagen, Betriebsdokumentation	authentisierter Zugriff, keine öffentliche Freigabe
Confidential	Kundenscope, Maßnahmen, Serviceberichte, Nutzerzuordnungen	tenantbezogen, verschlüsselt, exportkontrolliert
Highly Confidential	Schwachstellen, kritische Risiken, Incidentdaten, Schlüsselreferenzen	need-to-know, Step-up, Masking, strengere Retention
Restricted Evidence	Auditnachweise, forensische Artefakte, rechtlich sensible Dokumente	Evidence Room, Vier-Augen-Freigabe, Legal Hold, starke Auditierung
Secret Material	Tokens, private Schlüssel, Recovery Codes	Secret Manager/HSM, niemals als Fachdatensatz oder Loginhalt

6.2 Klassifikationsmetadaten

Jedes relevante Objekt oder Artefakt besitzt mindestens:

- Klassifikation und Begründung,
- Tenant und Datenraum,
- Data Owner und fachlichen Steward,
- personenbezogene Kategorien,
- Zweck und erlaubte Nutzungen,
- Region und Residenzanforderung,
- Retention Schedule,
- Export- und Sharingregel,

- Legal-Hold-Status,
- Masking- und Redactionprofil,
- Zeitpunkt und Quelle der Klassifikation.

Eine niedrigere Klassifikation erfordert eine dokumentierte Neubewertung. Automatische Klassifikation darf Vorschläge liefern, aber Highly-Confidential- oder Restricted-Evidence-Inhalte nicht autonom herabstufen.

7. Identitäts-Lifecycle

7.1 Identitätstypen

- Kundenbenutzer,
- Berater und Managed-Service-Personal,
- externe Auditoren und Lieferanten,
- Plattform- und Security-Administratoren,
- Service Accounts und Workload Identities,
- Connector Identities,
- kurzlebige Demo- oder Testidentitäten,
- später klar gekennzeichnete KI-/Agentenidentitäten.

Jede Identität besitzt einen eindeutigen Principal, Herkunft, Assurance-Level, Status, Owner, Mandantenzuordnung, Rollenbindungen, letzte Überprüfung und Ablauf- oder Deprovisionierungsregel.

7.2 Joiner, Mover, Leaver

- **Joiner:** Einladung oder Föderation erzeugt keine Fachrechte, bevor Membership und Tenant bestätigt wurden.
- **Mover:** Rollen-, Team-, Service- oder Kundenwechsel werden als Versionen mit Gültigkeitszeit modelliert; alte Rechte enden explizit.
- **Leaver:** Sessions, Refresh Tokens, API Keys, Delegationen, offene Freigaben und persönliche Links werden widerrufen.
- **Dormant Account:** Inaktive Konten werden nach konfigurierter Frist gesperrt und einem Review zugeführt.
- **Orphaned Account:** Service Accounts ohne aktiven Owner werden deaktiviert oder eskaliert.

Identity-Synchronisationen dürfen einen lokalen Break-Glass-Owner nicht still löschen. Konflikte gehen in einen Reconciliation Case.

8. Authentisierung

8.1 Standardverfahren

Produktive Mandanten verwenden bevorzugt Enterprise Federation über OIDC oder SAML. Lokale Passwörter sind nur für klar begrenzte Demo-, Recovery- oder Übergangsszenarien zulässig. OAuth-/OIDC-Implementierungen folgen aktuellen Sicherheitspraktiken: Authorization Code Flow mit PKCE, exakte Redirect URI, sichere Clientauthentisierung, eingeschränkte Scopes und keine veralteten impliziten Flows.

8.2 MFA und Passkeys

- privilegierte Plattform-, Tenant-Admin-, Support- und Schlüsselrollen benötigen MFA,
- Risikoakzeptanz, massenhafter Export, Break Glass und Recovery können Step-up verlangen,
- phishingresistente Passkeys oder Hardware-Authentikatoren werden bevorzugt,
- SMS gilt nicht als bevorzugter Faktor für hochprivilegierte Tätigkeiten,
- Recovery Codes werden einmalig angezeigt, gehasht gespeichert und rotierbar gemacht,
- verlorene Faktoren lösen Identitätsprüfung und dokumentierte Wiederherstellung aus.

8.3 Authentisierungs-Assurance

Die Session speichert nicht nur „eingeloggt“, sondern:

- IdP und Authentisierungszeit,
- verwendete Faktoren,
- Assurance-/ACR-Wert,
- Geräte- oder Risikosignal, soweit zulässig,
- letzte Step-up-Zeit,
- Session- und Tokenablauf,
- Widerrufs- und Anomaliehinweise.

9. Session Security und kontinuierliche Zugriffsprüfung

Sessions verwenden sichere, HttpOnly- und SameSite-Cookies oder gleichwertige BFF-Muster. Tokens werden nicht dauerhaft im Browser-Local-Storage abgelegt. Kritische Sessions besitzen kürzere Lebenszeit; Refresh und Idle Timeout sind getrennt konfigurierbar.

Eine Session wird neu bewertet bei:

- Rollen- oder Membershipänderung,
- Mandantenwechsel,
- Passwort-/Faktor-Reset,
- Security Incident oder Account Compromise,
- ungewöhnlicher Geo-/Geräteänderung, soweit zulässig,
- Aktivierung eines hochsensiblen Datenraums,
- Break-Glass- oder Supportzugriff,
- Rückkehr zu einer lange inaktiven Seite vor kritischer Aktion.

Die Plattform unterstützt sofortigen Widerruf und perspektivisch Continuous Access Evaluation über standardisierte Security Events. Bereits gestartete Workflows prüfen vor kritischen Schritten die aktuelle Autorisierung erneut; ein alter Startkontext genügt nicht.

10. Autorisierungsmodell: RBAC, ABAC und Beziehungen

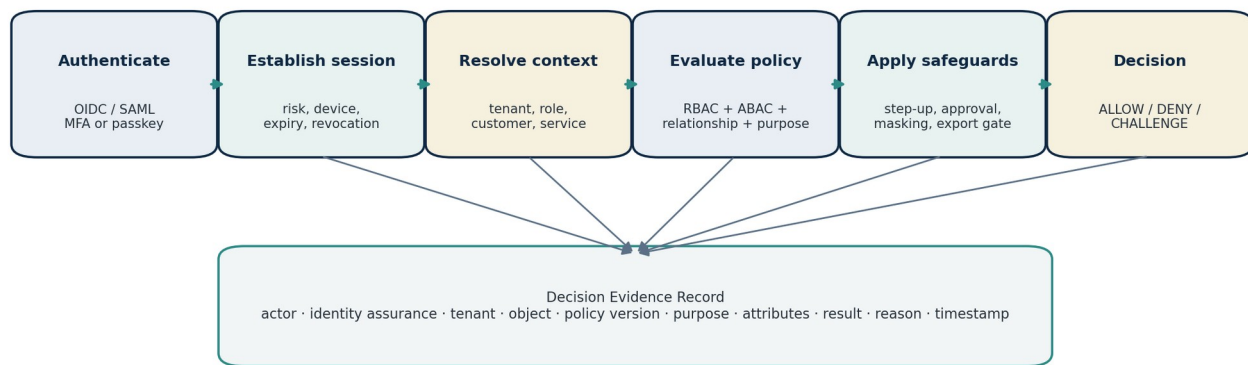
10.1 Policy-Entscheidung

Ein Zugriffsentscheid verwendet mindestens:

- Principal und Identity Assurance,
- aktiven Tenant und gegebenenfalls Kunden-/Servicekontext,
- Aktion,
- Objekt und Datenklasse,
- Rollenbindung,
- Beziehung zum Objekt,
- Zweck und Workflowzustand,
- Delegation und Gültigkeit,
- Policy- und Methodenversion,
- zusätzliche Guards wie Step-up, Vier-Augen-Prinzip oder Exportlimit.

Access Decision Pipeline

An allow decision is the result of explicit evidence, not a role name alone.



Every protected action is re-evaluated server-side. Missing context means deny.

Abbildung 2: Ein Zugriff wird aus Identity Assurance, Tenantkontext, Rollen, Attributen, Beziehungen, Zweck und zusätzlichen Safeguards nachvollziehbar entschieden.

10.2 RBAC als verständliche Basis

Kanonische Basisrollen umfassen unter anderem Executive, CISO, ISMS Manager, Control Owner, Asset Owner, Contributor, Auditor, Berater, Engagement Manager, Service Lead, Tenant Admin, Platform Operator, Security Operator und Read-only Reviewer. Rollen sind keine universellen Rechtspakete, sondern innerhalb von Tenant, Scope, Service oder Datenraum gebunden.

10.3 ABAC für Kontext

ABAC-Attribute umfassen:

- Datenklasse,
- Region und Residency,
- Risikoschwelle,
- Budget- oder Freigabelimit,
- Servicevertrag,
- Auditstatus,
- Objektstatus,
- zeitliche Gültigkeit,
- Unternehmens- oder Organisationseinheit,
- Session Assurance,
- Zweck der Verarbeitung.

10.4 ReBAC für fachliche Beziehungen

Beziehungsbezogene Regeln beantworten beispielsweise:

- Ist die Person Owner oder Reviewer dieses Controls?
- Ist der Berater dem Engagement und dem Kunden aktiv zugeordnet?
- Wurde der Auditor für diesen Audit Scope eingeladen?
- Ist die Person Beteiligter am Work Item oder Genehmiger der Decision Card?
- Gehört ein Evidence Artefact zu einem freigegebenen Audit Room?

10.5 Policy Lifecycle

Policies werden versioniert, getestet, reviewt und mit Aktivierungszeit veröffentlicht. Eine Policyänderung erzeugt Impactanalyse und Simulation gegen Testrollen. Produktivänderungen mit breiter Wirkung benötigen Vier-Augen-Freigabe. Rollback ist vorgesehen; alte Entscheidungen bleiben mit der damals gültigen Policyversion nachvollziehbar.

11. Mandantenisolation und Kontextwechsel

11.1 Mehrschichtige Isolation

Die Standardisolation umfasst:

- serverseitig abgeleiteten Tenant Context,
- tenantbewusste Repositories und Query Services,
- PostgreSQL Row Level Security,
- tenantbezogene Storage-Prefixes und Zugriffspolicies,
- tenantbezogene Queue- und Jobmetadaten,
- getrennte Connector Connections und Secret References,
- tenantgefilterte Search- und Graphprojektionen,
- tenantbezogene Report Snapshots und Cache Keys,
- Telemetrie ohne unzulässige Cross-Tenant-Inhalte,
- tenantselektiven Export, Löschung und Restore.

11.2 Kontextwechsel

Ein Wechsel zwischen Kunden oder Rollen ist sichtbar und explizit. Der aktive Kontext erscheint in Header, Breadcrumb, Report und kritischem Dialog. Offene Tabs erhalten einen Kontext-Nonce; ein Request mit veraltetem Mandantenkontext wird abgelehnt und nicht automatisch auf den neuen Kunden umgeschrieben.

11.3 Metadatenlecks

Tests prüfen nicht nur Datensätze, sondern auch:

- Trefferzahlen,
- Autocomplete,
- Graphkanten,
- Fehlertexte,
- IDs und URLs,
- Downloadgrößen und Dateinamen,
- Timingunterschiede,
- Benachrichtigungen,
- Caches,
- Reportvorschauen,
- Dead Letters und Operations Screens.

11.4 Assurance-Stufen

Höhere Kundentiers können dedizierte Schema-, Datenbank-, Schlüssel-, Storage-, Netzwerk- oder Deploymentgrenzen erhalten. Der Wechsel einer Isolationsstufe benötigt Migrationsplan, Validierung, Downtime-/Rollbackregeln und tenantspezifischen Restore-Test.

12. Privilegierte Administration

12.1 Rollen und Grenzen

- Tenant Admin verwaltet Mandantenmitgliedschaften und zulässige Konfiguration, sieht aber keine Plattformsecrets.
- Platform Operator betreibt technische Komponenten, erhält standardmäßig keinen Inhaltzugriff auf Kundendaten.
- Security Operator untersucht Security Events mit maskierten Daten und kontrollierten Deep-Dive-Rechten.
- Key Custodian verwaltet Schlüsseloperationen, kann aber nicht allein fachliche Daten exportieren.
- Database/Infrastructure Operator nutzt getrennte technische Identitäten und keine geteilten Rootkonten.

12.2 Privileged Access Management

- Just-in-Time-Aktivierung statt dauerhafter Adminrechte,
- separate Adminidentität für privilegierte Tätigkeiten,
- starke MFA und Step-up,
- zeitliche Begrenzung und automatische Rücknahme,
- Ticket, Zweck und Genehmiger,
- Sessionaufzeichnung oder detaillierte Command-/Action-Auditierung bei besonders kritischen Pfaden,
- regelmäßige Access Reviews,
- Alarm bei ungewöhnlicher Nutzung oder Selbstgenehmigung.

13. Supportzugriff und Break Glass

13.1 Supportzugriff

Supportzugriff ist kein allgemeiner Betreiberzugriff. Er benötigt:

1. Kunden- oder Incidentbezug,
2. konkreten Zweck und Scope,
3. minimale Rolle,

4. begrenzte Zeit,
5. Genehmigung gemäß Supporttier,
6. Step-up Authentication,
7. sichtbaren Sessionbanner,
8. vollständigen Audit Record,
9. nachträgliche Kundensicht und Review.

Read-only und Masking sind Standard. Download, Export, Rollenänderung oder Löschung benötigen zusätzliche Freigabe.

13.2 Break Glass

Break Glass ist nur für akute Sicherheits-, Verfügbarkeits- oder Recoveryfälle vorgesehen. Der Prozess umfasst:

- klar definierte Auslöser,
- Zwei-Personen-Prinzip oder dokumentierte Notfallausnahme,
- kurze Laufzeit,
- maximal erforderlichen Scope,
- automatische Benachrichtigung an Security und Kundenkontakt,
- unveränderbaren Audit Record,
- verpflichtendes Post-Event-Review,
- Rotation betroffener Credentials,
- Test mindestens in vereinbartem Rhythmus.

Ein Break-Glass-Konto wird nicht für Routinearbeit, Reporting oder Komfortzugriffe verwendet.

14. Service Accounts, Workload Identities und Agenten

Service Accounts besitzen Owner, Zweck, erlaubte Systeme, Scopes, Umgebung, Ablauf und Rotationsregel. Persönliche Nutzercredentials werden nicht für Worker, CI/CD oder Connectoren verwendet.

- Workloads verwenden bevorzugt kurzlebige, föderierte Identitäten statt statischer Secrets.
- Connectoridentitäten sind pro Mandant und Connection getrennt.
- Schreibende Integrationen nutzen getrennte Scopes und gegebenenfalls getrennte Credentials.
- Agenten und Automationen handeln mit eigener, klar sichtbarer Identität; ihre Aktionen werden nicht dem orchestrierenden Menschen zugerechnet.
- Kritische Agentenaktionen benötigen Human Gate und erneute Policyprüfung.
- Nicht genutzte Workload Identities werden automatisch erkannt und deaktiviert.

15. Kryptografie und Transport Security

15.1 In Transit

- externe und interne HTTP-Kommunikation verwendet TLS nach aktuellem sicheren Profil,
- veraltete Protokolle und schwache Cipher werden deaktiviert,
- Zertifikate werden automatisiert erneuert und überwacht,
- interne Servicekommunikation erhält bei höherer Assurance mTLS oder Workload Identity,
- Webhooks werden zusätzlich signiert oder mit nachweisbarer Senderauthentisierung geschützt,
- E-Mail ist kein Transport für unverschlüsselte Restricted Evidence.

15.2 At Rest

- Datenbank, Object Storage, Backups und Snapshots werden verschlüsselt,
- besonders sensible Artefakte können zusätzlich anwendungsseitige Envelope Encryption erhalten,
- Schlüssel und Daten werden getrennt verwaltet,
- temporäre Render-, Scan- und Importdateien unterliegen derselben Schutzklasse,
- lokale Entwicklungsumgebungen verwenden nur synthetische oder freigegebene Daten.

15.3 Feld- und Objektverschlüsselung

Feldverschlüsselung ist für wenige hochsensible Werte vorgesehen, nicht als Ersatz für saubere Autorisierung. Such- und Reportinganforderungen werden vor Auswahl berücksichtigt. Secret Material wird grundsätzlich nicht als verschlüsseltes Fachfeld behandelt, sondern im Secret Manager referenziert.

16. Key Management und kryptografische Agilität

Der Key Lifecycle umfasst Erzeugung, Aktivierung, Nutzung, Rotation, Sperrung, Wiederherstellung, Archivierung und Vernichtung. Jeder Schlüssel besitzt Owner, Zweck, Algorithmus, Region, Gültigkeit, Schutzlevel und abhängige Datenklassen.

- produktive Root- und Master Keys liegen in verwaltetem KMS oder HSM,
- Tenant Keys können nach Assurance-Tier getrennt werden,
- Rotation muss alte Daten weiterhin kontrolliert entschlüsseln können,
- Key Usage wird auditierbar,
- Schlüsselzugriff folgt Separation of Duties,
- verlorene oder kompromittierte Schlüssel lösen Incident- und Re-encryption-Prozess aus,
- Algorithmen und Mindestlängen werden als Policy versioniert,
- kryptografische Defaults werden regelmäßig gegen aktuelle Standards geprüft.

17. Secrets Management

Secrets umfassen Connector Credentials, Datenbankzugänge, Signing Keys, API Secrets, Recoverymaterial und externe Service Tokens.

- Speicherung ausschließlich im Secret Manager oder einer sicheren lokalen Entwicklungsersatzlösung,
- Anwendungen speichern Referenzen, keine Klartexte,

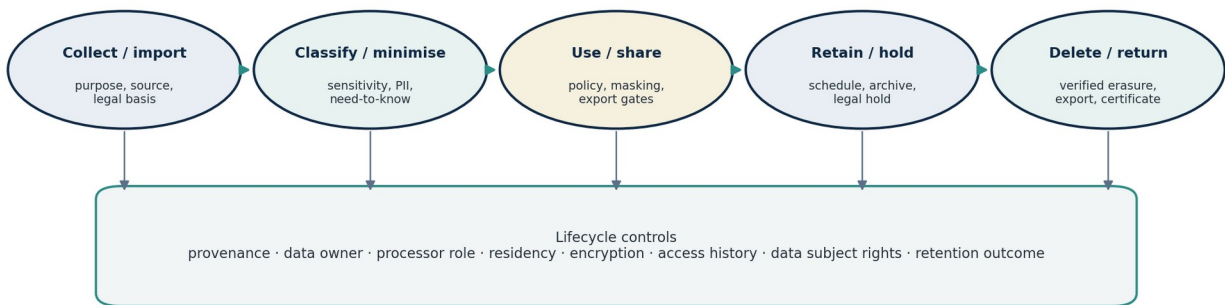
- Secrets werden nie in Git, Ticket, Chat, Prompt, Screenshot oder Report eingebettet,
- Zugriff ist workload- und umgebungsbezogen,
- automatische Rotation, wenn Anbieter und Prozess dies unterstützen,
- Ablauf, letzter Zugriff, Owner und Rotation werden überwacht,
- Secret Scanning blockiert Commits und Buildartefakte,
- Incident Playbooks existieren für Leaks und unklare Herkunft.

18. Datenschutz-Lifecycle

Datenschutz wird über einen kontrollierten Lifecycle gesteuert: Erhebung oder Import, Klassifikation, Minimierung, zulässige Nutzung, Weitergabe, Aufbewahrung, Legal Hold, Export und verifizierte Löschung.

Data Protection Lifecycle

Purpose, classification and retention travel with the data from ingestion to verified deletion.



No “delete” button without dependency analysis; no legal hold without owner, scope and expiry.

Abbildung 3: Zweck, Klassifikation, Zugriff, Aufbewahrung, Legal Hold, Export und verifizierte Löschung begleiten Daten über ihren gesamten Lebenszyklus.

Für jede Verarbeitung werden mindestens Zweck, Datenkategorien, betroffene Rollen, Quelle, Empfänger, Aufbewahrung und Sicherheitsmaßnahmen dokumentiert. Neue Integrationen oder Produktfunktionen erzeugen einen Privacy Impact Check. Eine vollständige Datenschutz-Folgenabschätzung wird vorbereitet, wenn die konkrete Verarbeitung voraussichtlich ein hohes Risiko für Rechte und Freiheiten erzeugt; die Plattform selbst entscheidet dies nicht rechtsverbindlich.

19. Datenschutzrollen und Verantwortlichkeiten

Je Deployment und Vertrag können Plattformbetreiber, Beratung und Kunde unterschiedliche Rollen als Verantwortlicher, gemeinsamer Verantwortlicher oder Auftragsverarbeiter besitzen. Diese Zuordnung wird pro Service und Datenfluss dokumentiert und nicht pauschal aus der Softwarebezeichnung abgeleitet.

Die Plattform unterstützt:

- Verzeichnis von Verarbeitungstätigkeiten und Datenflüssen,
- Data Owner, Privacy Owner und Processor/Subprocessor Zuordnung,
- Vertrags- und Weisungsbezug,
- Zweck- und Empfängermatrix,
- Datenresidenz und internationale Übermittlungen,
- technische und organisatorische Maßnahmen,
- Datenschutzvorfälle und Betroffenenanfragen,
- Nachweise von Löschung, Export und Supportzugriff.

Rechtsbewertung, Rechtsgrundlage und Vertragsrollen benötigen fachjuristische Freigabe. Dieses Konzept ersetzt keine Rechtsberatung.

20. Zweckbindung, Datenminimierung und personenbezogene Daten

20.1 Personenbezug reduzieren

- Rollen- und Verantwortlichkeitsreferenzen werden bevorzugt statt vollständiger HR-Profiles importiert.
- Private Kontaktdaten, Gehalt, Gesundheitsdaten oder nicht benötigte Performanceinformationen werden nicht übernommen.
- Telemetrie nutzt pseudonyme User IDs, soweit Klarnamen nicht erforderlich ist.
- Beraterproduktivitäts-KPIs werden nicht als verdeckte Personenbewertung gestaltet.
- Prompt- und KI-Kontext wird auf erforderliche Ausschnitte reduziert.
- Rohpayloads externer Systeme erhalten kurze Retention und werden nach erfolgreicher Normalisierung gelöscht, sofern kein Reconciliation-Bedarf besteht.

20.2 Purpose Binding

Zwecke werden als maschinenlesbare Referenzen an Datenräume und Verarbeitungspfade gebunden, beispielsweise Service Delivery, Audit Evidence, Security Incident, Customer Support oder Product Analytics. Zweckwechsel oder neue Nutzung benötigen Review und gegebenenfalls neue Einwilligungs-, Vertrags- oder Rechtsgrundlagenprüfung.

20.3 Besondere Kategorien und Beschäftigtendaten

Die Standardplattform ist nicht darauf ausgelegt, besondere Kategorien personenbezogener Daten aktiv zu verarbeiten. Falls Kunden solche Inhalte in Evidence oder Incidents hochladen, greifen Restricted-Evidence-Regeln, Warnung, Minimierung, strengere Zugriffe und gegebenenfalls gesonderte Datenschutzfreigabe. Beschäftigtendaten und personenbezogene Performanceauswertung benötigen Mitbestimmungs- und Arbeitsrechtsprüfung.

21. Betroffenenrechte, Auskunft und Datenportabilität

Die Plattform stellt Administratoren kontrollierte Funktionen bereit, um relevante personenbezogene Daten zu finden, zu exportieren, zu korrigieren, einzuschränken oder zu löschen. Die Funktion berücksichtigt:

- Identitätszuordnung über externe und interne IDs,
- strukturierte Fachobjekte,
- Kommentare und Work Items,
- Audit Records mit gesetzlichen oder vertraglichen Aufbewahrungsgrenzen,
- Dateien und Reports,
- Search-, Cache- und Analyticsprojektionen,
- aktive Backups und Restorefenster,
- Legal Hold,
- Daten in Subprozessoren.

Ein Betroffenenexport enthält keine Rechte oder vertraulichen Daten anderer Personen und Mandanten. Audit Records können bei berechtigter Aufbewahrung pseudonymisiert oder eingeschränkt statt gelöscht werden. Die Entscheidung wird dokumentiert.

22. Retention, Legal Hold und verifizierte Löschung

22.1 Retention Schedule

Retention wird pro Datenklasse und Zweck festgelegt, nicht als eine globale Zahl. Typische Kategorien sind:

- Security Logs,
- Debug Logs,
- Canonical Audit Records,
- Evidence Artefacts,
- Reports und Snapshots,
- Work Items und Kommunikation,
- Connector Raw Payloads,
- Backups,
- Demo- und Testdaten,
- Support- und Incidentunterlagen.

22.2 Legal Hold

Legal Hold besitzt Owner, Grund, Scope, Start, Reviewdatum und Ablauf. Er stoppt automatisierte Löschung nur für betroffene Objekte und abgeleitete Artefakte. Ein unbegrenzter globaler Hold ohne Review ist unzulässig.

22.3 Löschworkflow

1. Löschberechtigung, Zweck und Tenant prüfen.
2. Abhängigkeiten, Auditpflichten, Legal Hold und aktive Reports analysieren.
3. Löschantrag und erwartete Auswirkungen anzeigen.
4. bei kritischen Daten Step-up und Freigabe einholen.
5. führende Datensätze, Objekte und Indizes löschen oder anonymisieren.
6. Cache, Search, Projektionen, temporäre Dateien und Exportlinks invalidieren.
7. Backuppauslauf oder gezielte kryptografische Löschung dokumentieren.
8. Verification Job ausführen und Löschzertifikat erzeugen.

Löschung wird nicht als sofortige physische Entfernung aus jedem unveränderbaren Backup behauptet, wenn technisch nur ein kontrollierter Backuppauslauf möglich ist. Das System zeigt den tatsächlichen Zustand und das späteste endgültige Ablaufdatum.

23. Datenresidenz, Subprozessoren und internationale Übermittlung

Jeder Tenant besitzt eine freigegebene Datenregion und zulässige Subprozessoren. Verarbeitung außerhalb der Region, neue Telemetrieziele oder externe KI-/Reportingdienste benötigen Impactprüfung und gegebenenfalls Kundenfreigabe.

Die Plattform führt ein Subprocessor Register mit:

- Anbieter und Leistung,
- Datenkategorien,
- Regionen und Transfermechanismus,
- Sicherheitsnachweisen,
- Vertragsstatus,
- Änderungsdatum,

- Kundenbenachrichtigung,
- Exit- und Löschweg.

Supportzugriffe aus anderen Regionen werden als Verarbeitung sichtbar und folgen denselben Zweck-, Freigabe- und Auditregeln.

24. Canonical Audit Records

Canonical Audit Records sind langlebige, strukturierte Fachobjekte. Sie werden mindestens erzeugt für:

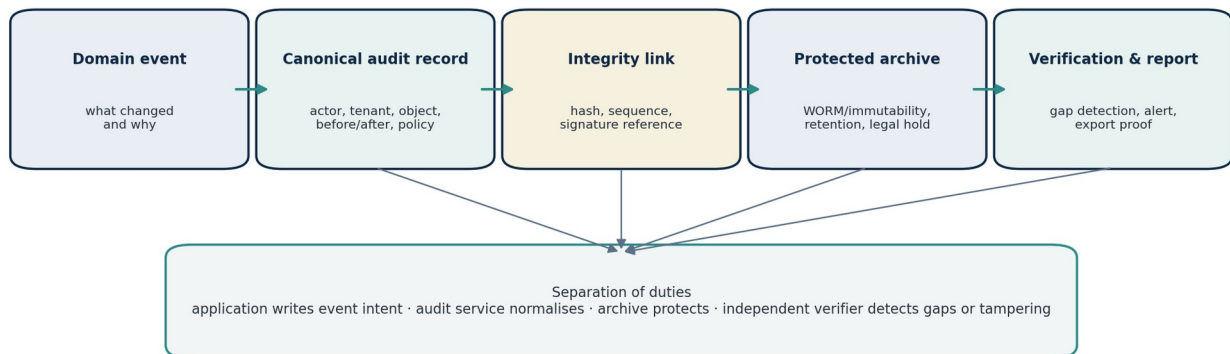
- Login-, MFA-, Recovery- und Sessionwiderrufereignisse,
- Membership-, Rollen-, Delegations- und Policyänderungen,
- Mandanten- oder Kundenkontextwechsel bei kritischen Aktionen,
- Risikoakzeptanz und Managemententscheidung,
- Control-, Finding-, Evidence- und Auditstatusänderung,
- Datei-Upload, Download, Export, Freigabe und Löschung,
- Support- und Break-Glass-Zugriff,
- Connector- und Workflowänderungen,
- produktive Konfigurations-, Schlüssel- und Retentionänderungen,
- Report Snapshot, Freigabe, Veröffentlichung und Korrektur,
- Incident-, Recovery- und Restoremaßnahmen,
- Agenten- oder Automationsaktionen mit fachlicher Wirkung.

24.1 Mindestfelder

- Record ID und Sequenz,
- Tenant und Datenraum,
- Actor und Actor Type,
- Identity Assurance und Sessionreferenz,
- Aktion, Objekt und Objektversion,
- vorheriger und neuer Zustand oder Delta,
- Grund, Ticket, Decision oder Workflow,
- Policy-/Methodenversion,
- Zeit in UTC und gegebenenfalls Clientzeit,
- Correlation und Causation ID,
- Ergebnis und Fehlercode,
- Integritätsreferenz,
- Klassifikation und Retention.

Audit & Evidence Integrity Chain

Business decisions, privileged actions and evidence changes remain independently verifiable.



Technical logs diagnose. Canonical audit records prove. Evidence artefacts substantiate.

Abbildung 4: Fachereignis, Canonical Audit Record, Integritätsverkettung, geschütztes Archiv und unabhängige Verifikation bilden eine beweisfähige Auditkette.

25. Technische Logs, Security Events und Detection

Technische Logs dienen Diagnose und Erkennung. Sie sind nicht identisch mit Audit Records. Logs folgen strukturierten Schemas und enthalten Correlation, Tenantpseudonym, Modul, Umgebung, Severity, Ergebnis und technische Ursache. Inhalte werden minimiert und redigiert.

25.1 Verbotene Loginhalte

- Passwörter und Recovery Codes,
- vollständige Access-/Refresh Tokens,
- private Schlüssel oder Secret Values,
- vollständige Evidence-Dokumente,
- unredigierte Prompt- oder Reportinhalte,
- unnötige personenbezogene Daten,

- komplette externe Rohpayloads ohne begründeten Debugmodus.

25.2 Detection Use Cases

- wiederholte Cross-Tenant-Zugriffsversuche,
- ungewöhnliche Rollen- oder Policyänderungen,
- massenhafter Export oder Download,
- Break-Glass-Nutzung,
- neue oder ungewöhnliche Connector-Schreibaktionen,
- Auditsequenzlücke oder Integritätsfehler,
- Malwarefund oder verdächtige Datei,
- Sessionanomalie und Token Replay,
- Secretzugriff außerhalb erwarteter Workloads,
- deaktivierte Securitykontrolle oder Retentionänderung,
- ungewöhnliche Fehlerrate, Ressourcenverbrauch oder Enumeration.

Alerts besitzen Owner, Severity, Tenantimpact, Runbook und Eskalation. Security Detection darf nicht heimlich zum Mitarbeitertracking werden.

26. Audit- und Evidence-Integrität

26.1 Manipulationsschutz

Canonical Audit Records werden append-only behandelt. Korrekturen erzeugen neue Records statt Überschreiben. Eine Integritätskette kann Sequenznummer, Hashverkettung, signierte Batch-Manifeste oder unveränderbaren Archivspeicher kombinieren.

26.2 Unabhängige Verifikation

Ein regelmäßiger Verifier prüft:

- Sequenzlücken,
- Hash- oder Signaturfehler,
- fehlende Objektversionen,
- nicht archivierte Audit Batches,
- Uhrzeit- und Quellenanomalien,
- unzulässige Retentionänderungen,
- Unterschiede zwischen Fachzustand und Auditprojektion.

26.3 Evidence Artefacts

Evidence besitzt Quelle, Hash, Dateityp, Erstell- und Uploadzeit, Gültigkeitszeitraum, Controlbezug, Reviewer, Freigabestatus, Klassifikation, Malware-Scanstatus, Retention und Version. Eine geänderte Datei ist eine neue Evidence-Version. Externe Links sind nur zulässig, wenn Zugriff, Verfügbarkeit und Integrität nachweisbar bleiben.

27. Application- und API-Sicherheit

Die technische Sicherheitsbaseline orientiert sich an einem aktuellen Application-Security-Verifikationsstandard und wird in Dokument 20C als ausführbare Test- und Quality-Gate-Matrix umgesetzt.

27.1 API-Regeln

- schema- und typvalidierte Inputs,
- serverseitige Objekt- und Funktionsautorisierung,
- sichere Pagination und Filter,
- stabile, nicht sensitive Fehlercodes,
- Rate Limits und Quoten nach Principal, Tenant und Route,
- Idempotency Keys für kritische Mutationen,
- Schutz vor Injection und unsicherer Deserialisierung,
- erlaubte Content Types und Größenlimits,
- ETag/Version für konfliktanfällige Updates,
- CSRF-Schutz bei Cookieauthentisierung,
- CORS nur für freigegebene Origins,
- keine unkontrollierte Mass Assignment,
- kein Trust in clientseitige Tenant- oder Rollenfelder.

27.2 Secure Design

Neue Funktionen benötigen Missbrauchsfälle, Sicherheitsinvarianten, Fehlerverhalten und Testfälle. „Input Validation“ ersetzt kein Threat Model. Besonders kritische Module sind Identity, Authorization, File Pipeline, Reporting, Connectoren, Workflow Gates, Search, Export, Tenant Migration und Supportzugriff.

28. Browser- und Frontend-Sicherheit

- strikte Content Security Policy,
- Schutz vor Clickjacking,
- sichere Cookieattribute,
- CSRF Token oder SameSite/BFF-Muster,
- kein Rendern unsanitärer HTML-Inhalte,
- sichere Markdown-/Rich-Text-Sanitization,
- Subresource-/Dependencykontrollen,
- keine Secrets oder sensiblen Daten in Browserlogs,
- Clipboard- und Downloadwarnungen bei Restricted Evidence,

- automatische Maskierung in öffentlichen Präsentationsmodi,
- Reauthentisierung vor kritischen Aktionen,
- sichere Behandlung von Deep Links und Redirects,
- Tab- und Context-Nonce gegen Mandantenverwechslung.

Frontend-Feature-Flags sind keine Autorisierung. DevTools, manipulierte Requests und direkte API-Aufrufe müssen dieselbe Ablehnung erhalten.

29. Datei-, Evidence-, Report- und Export-Sicherheit

29.1 Upload Pipeline

1. Upload in Quarantänebereich.
2. Dateigröße, Typ und Signatur prüfen.
3. Malware- und gegebenenfalls Content-Scan.
4. Metadaten und aktive Inhalte analysieren.
5. Hash, Klassifikation und Provenance speichern.
6. nur freigegebene Renderer/Parser verwenden.
7. nach erfolgreichem Scan in tenantbezogenen Storage verschieben.

Office-Makros, eingebettete Objekte, Archive, PDFs mit aktiven Inhalten und passwortgeschützte Dateien erhalten gesonderte Regeln. Preview und Parsing laufen isoliert und ressourcenbegrenzt.

29.2 Reports und Exporte

- Report basiert auf eingefrorenem, freigegebenem Snapshot,
- Zielgruppe und Datenklasse bestimmen Inhalt,
- Hidden Slides, Notizen, Metadaten und eingebettete Dateien werden geprüft,
- sensible Exporte benötigen Step-up und gegebenenfalls Approval,
- Downloads verwenden kurzlebige Links,
- Wasserzeichen, Empfänger und Ablauf sind konfigurierbar,
- jeder Download, Versand und Widerruf wird auditiert,
- Exportpakete erhalten Manifest und Hashliste,
- nachträgliche Korrekturen erzeugen neue Version, keine stille Ersetzung.

30. Integrations-, Webhook- und Egress-Sicherheit

Connectoren folgen dem Modell aus Dokument 17, ergänzt um:

- Least-Scope-Credentials,
- getrennte Read- und Write-Pfade,
- Allowlist für Hosts, Ports und Protokolle,
- Schutz vor SSRF und DNS-Rebinding,
- Zertifikats- und Signaturprüfung,
- Webhook Replay Protection,
- Payloadgrößen- und Schemalimits,
- Quarantäne/Staging vor fachlicher Übernahme,
- Secrets Reference statt Klartextkonfiguration,
- Rate Limit, Circuit Breaker und Kostenlimit,
- Mandant, Connection und Purpose in jedem Event,
- Freigabe für neue Schreibaktionen oder Datenempfänger.

Externe Systeme werden nicht automatisch als vertrauenswürdige Quelle behandelt. Provenance, Aktualität und Confidence bleiben sichtbar.

31. Secure SDLC und Software Supply Chain

31.1 Entwicklungspraktiken

- Security Requirements und Threat Models vor kritischer Implementierung,
- Branch Protection und verpflichtende Reviews,
- getrennte Rollen für Implementierung und Freigabe kritischer Änderungen,
- Secret-, SAST-, Dependency-, IaC- und Container-Scanning,
- Software Bill of Materials für Releases,
- gepinnte oder kontrollierte Dependencies,
- reproduzierbare Builds soweit praktikabel,
- signierte Artefakte und Provenance,
- OIDC Workload Identity für CI/CD statt langlebiger Cloud Secrets,
- sichere Defaultkonfiguration und Hardening,
- dokumentierte Vulnerability Disclosure und Patchprozesse,
- Security Tests als Bestandteil der Definition of Done.

Die stabile Referenz ist NIST SSDF 1.1; der Entwurf 1.2 wird beobachtet, aber nicht still als verbindlicher Standard behandelt, solange er Draft ist.

31.2 Lieferkettengovernance

Neue Libraries, Actions, Container Images und Buildtools benötigen Owner, Quelle, Lizenz-, Sicherheits- und Wartungsprüfung. Kritische Dependencies erhalten bevorzugt Version Pinning und Updatefenster. Verwaiste oder unnötige Pakete werden entfernt. Ein kompromittierter Build Runner darf nicht automatisch produktive Daten oder Secrets erreichen.

32. Schwachstellenmanagement

Der Lifecycle umfasst Intake, Triage, Validierung, Priorisierung, Owner, Remediation, Test, Veröffentlichung, Kundenkommunikation und Abschluss.

Priorisierung berücksichtigt:

- technische Schwere,
- Exploitbarkeit und aktive Ausnutzung,
- betroffene Datenklasse und Tenanzahl,
- Internetexposition,
- vorhandene Kompensationskontrollen,
- Business- und Managed-Service-Auswirkung,
- Verfügbarkeit eines Fixes,
- Supply-Chain-Reichweite.

SLAs werden in Dokument 20C und späteren Betriebsverträgen konkretisiert. Ausnahmen benötigen Risikoakzeptanz, Ablaufdatum und kompensierende Maßnahme. Sicherheitsupdates dürfen nicht durch normale Featurepriorisierung verdrängt werden.

33. Security Testing und Assurance

33.1 Automatisierte Tests

- Autorisierungs-Matrix-Tests,
- Cross-Tenant-Negativtests,
- RLS- und Repository-Tests,
- API- und Schema-Fuzzing,
- SAST, Dependency, Secret und IaC Scans,
- Dateipipeline- und Malware-Testfixtures,
- Auditvollständigkeits- und Hashkettenprüfung,
- Retention- und Löschtests,
- Backup-/Restore- und Tenant-Restore-Test,
- Security Header und Browserkontrollen,
- Rate-Limit- und Ressourcenverbrauchstests.

33.2 Manuelle Assurance

- Threat-Model-Review,
- Code Review kritischer Module,
- Penetrationstest vor Produktivpilot und danach risikobasiert,
- Privileged-Access- und Supportprozessreview,
- Tabletop Exercise für Incident und Breach,
- Restore Game Day,
- Datenschutz- und Datenflussreview,
- unabhängige Audit-Record-Verifikation.

33.3 Release Gates

Ein Release wird blockiert bei kritischer Cross-Tenant-Lücke, ungeklärtem Secret Leak, fehlender Autorisierung, manipuliertem Auditpfad, ungeprüfter Datenmigration oder fehlendem Recoverypfad. Scannerwarnungen werden risikobasiert triagiert; „grüner Scan“ allein ist keine Freigabe.

34. Security Incident Response

Incident Response ist in den gesamten Risikomanagement- und Betriebsprozess eingebettet. Der Lifecycle umfasst Vorbereitung, Erkennung, Analyse, Eindämmung, Beseitigung, Wiederherstellung und Verbesserung.

34.1 Incidentklassen

- Identity/Account Compromise,
- Cross-Tenant Data Exposure,
- Secret oder Key Compromise,
- Malware in Evidence/File Pipeline,
- Supply-Chain-Kompromittierung,
- Integrations- oder Connector Missbrauch,
- Audit-/Log-Manipulation,
- Verfügbarkeits- oder Ressourcenangriff,
- Privacy Incident,
- Fehlkonfiguration oder fehlerhafte Automation.

34.2 Incident Command

Jeder Incident besitzt Incident Commander, Security Lead, Technical Lead, Privacy/Legal Contact, Customer Communication Owner und Scribe. Rollen können in kleinen Teams kombiniert werden, aber Entscheidungen und Zeitlinie bleiben dokumentiert.

34.3 Forensische Bereitschaft

- korrelierbare Zeit und IDs,
- geschützte Audit- und Security Logs,
- Snapshot- und Artefaktsicherung,
- Chain of Custody,
- kontrollierte Support-/Adminzugriffe,
- bekannte Datenresidenz,

- Fähigkeit zum Session-, Token-, Key- und Connectorwiderruf,
- vorbereitete Kunden- und Behördenkommunikation.

35. Datenschutzverletzungen und Benachrichtigung

Ein Security Incident wird auf möglichen Personenbezug geprüft. Der Workflow unterstützt:

- betroffene Datenkategorien und Personen,
- Umfang, Zeitraum und Mandanten,
- Vertraulichkeits-, Integritäts- und Verfügbarkeitsauswirkung,
- Risiko für Rechte und Freiheiten,
- Verantwortlicher/Auftragsverarbeiter und vertragliche Meldewege,
- Zeitstempel für Kenntnis und Entscheidungen,
- Maßnahmen zur Eindämmung,
- Behörden- und Betroffenenkommunikation,
- Nachweis, warum eine Meldung erfolgt oder nicht erfolgt ist.

Die Plattform kann Fristen und Templates unterstützen, entscheidet aber nicht autonom über rechtliche Meldepflichten. Bei NIS2-, DORA- oder anderen sektoralen Meldepflichten werden separate, konfigurierbare Playbooks verwendet.

36. Business Continuity, Recovery und Sicherheitswiederherstellung

Security Recovery baut auf Dokument 18 auf und ergänzt:

- Wiederherstellung nur aus verifizierten Backups,
- Reauthentisierung und Schlüsselrotation nach Kompromittierung,
- saubere Wiederanbindung von Connectoren,
- Replaykontrolle für Events und Workflows,
- Prüfung von Audit- und Evidence-Integrität,
- Tenantselektion und Kundenzustimmung bei Restore,
- dokumentierte Abweichungen zwischen RPO und fachlichem Zustand,
- erhöhte Beobachtung nach Wiederanlauf,
- kontrollierte Aufhebung von Notfallrechten.

Recovery gilt erst als abgeschlossen, wenn Sicherheitsursache, Datenintegrität, Kundenkommunikation, offene Risiken und Follow-up-Maßnahmen dokumentiert sind.

37. Security Governance und Verantwortlichkeiten

37.1 Kernrollen

Rolle	Verantwortung	darf nicht allein
Product Security Owner	Security Baseline, Threat Models, Freigaben	eigenes kritisches Finding schließen und freigeben
Privacy Owner/DPO-Schnittstelle	Datenflüsse, Privacy Reviews, Rechte	Rechtsgrundlage ohne zuständige Freigabe festlegen
IAM/Authorization Owner	Rollen, Policies, Access Reviews	eigene privilegierte Rechte dauerhaft genehmigen
Platform Security Engineer	Hardening, Detection, Secrets, Response	Auditintegrität allein bestätigen
Tenant Security Admin	tenantbezogene Benutzer und Konfiguration	Betreiber- oder fremde Mandantenrechte vergeben
Audit Integrity Reviewer	Auditkette und Evidence-Prozess prüfen	Auditdaten operativ verändern
Incident Commander	Incident koordinieren	fachliche Kundenentscheidung ohne Owner treffen
Key Custodian	Key Lifecycle und KMS Policy	Datenexport und Schlüsselzugriff kombinieren

37.2 Reviews und Rhythmen

- monatlicher Access Review privilegierter Betreiberrollen,
- quartalsweiser Tenant-Admin- und externer Auditor Review oder risikobasiert,
- regelmäßiger Review von Service Accounts, Secrets und Connector Scopes,
- jährliche oder ereignisbezogene Threat-Model- und Baselineprüfung,
- regelmäßige Restore-, Break-Glass- und Incidentübungen,
- Security Steering mit offenen Risiken, Findings und technischen Schulden.

38. Shared Responsibility und kundenseitige Sicherheitskontrollen

Die Plattform kann sichere Funktionen bereitstellen, aber der Kunde bleibt für zutreffende Rollen, Scope, Datenklassifikation, Evidencefreigabe, Rechtsgrundlagen, Benutzerdeprovisionierung und eigene Quellsysteme mitverantwortlich. Service Charter und Responsibility Blueprint aus Dokument 13 und 16 machen diese Grenzen sichtbar.

Kundenseitige Sicherheitskonfiguration umfasst:

- freigegebene Identity Domains,
- MFA- und Sessionpolicy,
- Tenant Admins und Delegationen,
- Datenklassen und Retention,
- zulässige Regionen und Subprozessoren,
- Supportzugriffsmodell,
- Export- und Reportfreigaben,
- Connector Scopes,
- Audit- und Incidentkontakte,
- gewünschte Isolations- und Key-Tier.

Unsichere Kundenwünsche werden nicht still umgesetzt. Die Plattform zeigt Risiko, Kompensationskontrolle, Freigabe und Ablauf einer Ausnahme.

39. Security & Privacy Control Center

Die Plattform besitzt eine eigene Betriebs- und Kundensicht für Security und Privacy. Sie zeigt nicht nur „compliant“, sondern:

- Identity- und MFA-Abdeckung,
- privilegierte aktive Rechte,
- offene Access Reviews,
- Support- und Break-Glass-Nutzung,
- Tenant-Isolation-Teststatus,
- Secret- und Key-Rotation,
- offene Security Findings,
- Audit-Record-Integrität,
- Datenklassen und Retentionverletzungen,
- Lösch- und Betroffenenanfragen,
- Subprozessor- oder Regionsänderungen,
- Security Incident und Recoverystatus,
- Secure-SDLC- und Release-Gate-Ergebnisse.

Kunden sehen ihre eigenen relevanten Kontrollen; Betreiber sehen aggregierte Betriebsrisiken ohne unnötigen Kundendateninhalt.

40. Sicherheitskonzept des privaten Demonstrators

Der Demonstrator verwendet ausschließlich synthetische Firmen-, Nutzer-, Risiko-, Evidence-, Incident- und Service-Daten. Trotzdem funktionieren folgende Kontrollen real:

- Login mit mehreren Demoidentitäten,
- Rollen- und Tenant Context,
- serverseitige Autorisierung,
- sichtbarer Kontextwechsel,
- Step-up-Simulation mit echtem Gate,
- Audit Records für Login, Rollenwechsel, Export und Supportzugriff,
- tenantbezogene Datenspeicherung und Negativtests,
- Quarantäne- und Scanstatus für Testdateien,
- kurzlebige Downloadlinks,
- Reportfreigabe und Versionierung,
- Supportzugriffs- und Break-Glass-Demo,
- Retention-/Löschsimulation mit Verification,
- Security Event und Incident Timeline.

Mock-IdP, Mock-KMS, Mock-Malware-Scanner und simulierte Security Signals sind zulässig, wenn sie sichtbar gekennzeichnet, austauschbar und in Produktionskonfiguration deaktiviert sind. Demoaccounts erhalten keine echten externen Schreibrechte.

41. End-to-End-Sicherheits- und Datenschutzszenarien

41.1 Berater wechselt Kundenkontext

1. Berater arbeitet in Alpha Manufacturing.
2. Er wechselt sichtbar zu Beta Health.
3. Ein alter Tab sendet eine Mutation mit Alpha-Context-Nonce.
4. Backend erkennt veralteten Kontext und verweigert die Mutation.
5. Audit Record dokumentiert die Ablehnung ohne Dateninhalt.
6. UI fordert Neuladen im korrekten Kontext.

41.2 Externer Auditor erhält Evidence-Zugang

1. Tenant Admin lädt Auditor für Audit und Zeitraum ein.
2. Auditor authentisiert sich mit MFA.
3. ReBAC erlaubt nur freigegebenen Audit Room.
4. Restricted Evidence benötigt Watermark und Downloadpolicy.
5. Einladung läuft automatisch ab; offene Sessions werden widerrufen.

41.3 Supportzugriff auf fehlerhaften Report

1. Kunde eröffnet Supportticket und erlaubt Zugriff auf einen Reportjob.
2. Supportrolle wird JIT read-only aktiviert.
3. Inhalte sind standardmäßig maskiert.
4. Support reproduziert Fehler über Snapshot und Renderlogs.

5. Download wird nicht erlaubt; Änderung erfolgt über normalen Fixprozess.
6. Kunde sieht Zeit, Zweck und Aktionen nach Abschluss.

41.4 Verdächtiger Massenexport

1. Nutzer startet Export vieler Highly-Confidential-Objekte.
2. Policy fordert Step-up, Zweck und Genehmigung.
3. Rate-/Volume-Anomalie erzeugt Security Alert.
4. Genehmiger lehnt ab; Exportjob wird nicht erzeugt.
5. Decision und Audit Record bleiben erhalten.

41.5 Connector Credential kompromittiert

1. Detection erkennt ungewöhnliche Nutzung.
2. Connection wird automatisch pausiert.
3. Secret wird widerrufen und rotiert.
4. betroffene Sync Runs und Datenänderungen werden analysiert.
5. Reconciliation und Kundenkommunikation werden gestartet.
6. Connector wird erst nach Test und Freigabe reaktiviert.

41.6 Betroffenenanfrage und Legal Hold

1. Privacy Admin sucht Daten einer Person über Identity Resolution.
2. System zeigt Datenobjekte, Reports, Kommentare und Aufbewahrungsgründe.
3. Ein Incidentfile steht unter Legal Hold und wird eingeschränkt statt gelöscht.
4. übrige Daten werden exportiert, korrigiert oder gelöscht.
5. Search, Cache und Projektionen werden verifiziert.
6. Abschlussbericht dokumentiert Ausnahmen und spätestes Löschdatum.

41.7 Audit-Integritätsfehler

1. Verifier erkennt Lücke in einer Auditsequenz.
2. betroffener Zeitraum und Mandant werden isoliert.
3. Fachoperationen mit hoher Kritikalität werden gegebenenfalls pausiert.
4. Outbox, Datenbank und Archiv werden korreliert.
5. Incident entscheidet zwischen technischer Verzögerung und Manipulationsverdacht.
6. Wiederherstellung und unabhängiger Nachweis werden dokumentiert.

41.8 Malware in Evidence

1. Datei landet in Quarantäne.
2. Scanner meldet Malware oder verdächtige aktive Inhalte.
3. Datei wird weder gerendert noch für Auditoren freigegeben.
4. Uploader und Security Owner erhalten kontrollierte Meldung.
5. Hash und Ereignis werden auditiert; Inhalt wird nicht in Logs kopiert.
6. Ersatznachweis wird angefordert.

42. Regulatorische und Standard-Mappings

Die Plattform ist framework-erweiterbar. Die folgenden Quellen dienen als Designanker, nicht als automatische Zertifizierung.

Designbereich	relevante Anker	Umsetzung in diesem Dokument
Datenschutzprinzipien	DSGVO Art. 5, 25, 32	Minimierung, Privacy by Default, risikoadäquate TOMs
Incident/Breach	DSGVO Art. 33/34, NIS2, DORA	Rollen, Zeitlinie, Meldeplaybooks, Nachweise
Cyber-Risikomaßnahmen	NIS2 Art. 21	Governance, Zugriff, Kryptografie, Supply Chain, Incident, Wirksamkeit
IKT-Risikomanagement	DORA Art. 6/9 und RTS	dokumentierter Rahmen, Monitoring, Assets, Resilienz, Rollen
Controls und Assurance	NIST SP 800-53 Rev. 5	Access, Audit, Incident, Privacy, Supply Chain, Assessment
Zero Trust	NIST SP 800-207/207A	identitäts- und policybasierte, kontinuierliche Zugriffsprüfung
Secure Development	NIST SP 800-218, BSI CON.8	Secure SDLC, Lieferkette, Tests, Schwachstellenmanagement
Application Security	OWASP ASVS 5.0.0, Top 10:2025	verifizierbare AppSec-Baseline und Risikokategorien
Logging	BSI OPS.1.1.5	sichere Erhebung, Speicherung, Auswertung und Entsorgung

Designbereich	relevante Anker	Umsetzung in diesem Dokument
OAuth/OIDC	RFC 9700	PKCE, exakte Redirects, restriktive Tokens und aktuelle BCPs

Kundenspezifische Zertifizierungen, nationale Umsetzungen und sektorale Anforderungen werden als versionierte Requirement Packs eingebunden und benötigen fachliche Validierung.

43. Globale Akzeptanzkriterien

- **19-AC01:** Jeder fachliche Request besitzt serverseitig validierten Tenant Context.
- **19-AC02:** Direkte API-Aufrufe können keine nur im UI versteckte Funktion nutzen.
- **19-AC03:** Cross-Tenant-Negativtests decken CRUD, Search, Graph, Files, Reports, Jobs und Fehlertexte ab.
- **19-AC04:** Rollenbindungen sind tenant-, scope- oder objektbezogen und zeitlich überprüfbar.
- **19-AC05:** Kritische Aktionen können Step-up und Vier-Augen-Freigabe erzwingen.
- **19-AC06:** Rollenentzug widerruft aktive Sessions oder verhindert spätestens die nächste kritische Operation.
- **19-AC07:** Supportzugriff ist JIT, zweckgebunden, genehmigt und kundenseitig nachvollziehbar.
- **19-AC08:** Break Glass ist getestet, zeitlich begrenzt und erzeugt ein verpflichtendes Review.
- **19-AC09:** Connectoren besitzen tenantbezogene Least-Scope-Credentials.
- **19-AC10:** Secrets erscheinen nicht in Git, Logs, Reports oder Promptartefakten.
- **19-AC11:** Datenbank, Storage, Backups und Transport sind nach freigegebener Policy verschlüsselt.
- **19-AC12:** Key Rotation kann ohne Verlust des kontrollierten Datenzugriffs durchgeführt werden.
- **19-AC13:** Jede relevante Datenklasse besitzt Owner, Zweck, Retention und Exportregel.
- **19-AC14:** Löschung invalidiert führende Daten, Search, Cache, Projektionen und Downloadlinks und erzeugt Verification.
- **19-AC15:** Legal Hold ist scoped, versioniert, befristet überprüfbar und auditierbar.
- **19-AC16:** Canonical Audit Records enthalten Actor, Tenant, Objekt, Änderung, Policyversion und Integritätsreferenz.
- **19-AC17:** Audit Records können nicht still überschrieben werden.
- **19-AC18:** Ein unabhängiger Verifier erkennt Sequenz- oder Integritätsfehler.
- **19-AC19:** Technical Logs enthalten keine Secrets oder vollständige Restricted Evidence.
- **19-AC20:** Uploads werden vor Nutzung quarantänisiert, validiert und gescannt.
- **19-AC21:** Reports und Exporte verwenden freigegebene Snapshots und kurzlebige Downloadpfade.
- **19-AC22:** API Security Tests decken Zugriff, Injection, Mass Assignment, Rate Limit und Fehlerfälle ab.
- **19-AC23:** Jede kritische Funktion besitzt Threat Model oder dokumentierte Missbrauchsfälle.
- **19-AC24:** CI/CD blockiert kritische Secret-, Dependency-, IaC- oder Containerbefunde.
- **19-AC25:** Releases erzeugen SBOM und nachvollziehbare Artefaktprovenance.
- **19-AC26:** Security Findings besitzen Severity, Owner, SLA, Ausnahmeablauf und Re-Test.
- **19-AC27:** Incident Playbooks existieren für Cross-Tenant-Leak, Secret Leak, Malware, Supply Chain und Auditmanipulation.
- **19-AC28:** Restore und Tenant Restore werden mit Integritäts- und Autorisierungsprüfung getestet.
- **19-AC29:** Datenschutzexporte schließen unzulässige Dritt- und Mandantendaten aus.
- **19-AC30:** Demo-Bypass, Mock-Secrets und synthetische Konten sind von Produktion technisch getrennt.

44. Festgelegte Entscheidungen

- **19-D01:** Das Sicherheitsmodell kombiniert RBAC, ABAC und beziehungsbezogene Regeln; RBAC allein ist nicht ausreichend.
- **19-D02:** Jede Autorisierungsentscheidung ist tenantgebunden und wird serverseitig erzwungen.
- **19-D03:** Deny by Default gilt für fehlende Policy, Attribute, Tenant Context und Securityabhängigkeiten.
- **19-D04:** Produktive Enterprise-Identität erfolgt primär über OIDC/SAML; lokale Konten bleiben Ausnahme.
- **19-D05:** Privilegierte und kritische Tätigkeiten benötigen MFA; phishingresistente Verfahren werden bevorzugt.
- **19-D06:** Privilegierte Betreiber- und Supportrechte werden Just-in-Time aktiviert.
- **19-D07:** Supportzugriffe sind zweckgebunden, zeitlich begrenzt, auditierbar und kundenseitig sichtbar.
- **19-D08:** Break Glass besitzt eigene Accounts/Mechanismen, nicht normale Alltagsrollen.
- **19-D09:** Service Accounts und Agenten verwenden eigene Workload Identities und Owner.
- **19-D10:** Datenklassifikation steuert Zugriff, Masking, Export, Retention und Löschung.
- **19-D11:** Secret Material wird im Secret Manager gehalten und nie als normales Fachobjekt gespeichert.
- **19-D12:** Canonical Audit Records, Technical Logs und Evidence Artefacts bleiben getrennte Datenarten.
- **19-D13:** Audit Records sind append-only und erhalten einen unabhängigen Integritätsnachweis.
- **19-D14:** Dateien werden vor Vorschau oder fachlicher Nutzung quarantänisiert und gescannt.
- **19-D15:** Reports und Exporte basieren auf freigegebenen, reproduzierbaren Snapshots.
- **19-D16:** Secure SDLC, SBOM, Scans, Reviews und Security Gates sind Bestandteil der Definition of Done.
- **19-D17:** Die stabile AppSec-Verifikationsbasis ist OWASP ASVS 5.0.0; Top 10:2025 dient ergänzend als Awareness- und Risikomodell.
- **19-D18:** Die stabile Secure-SDLC-Referenz bleibt NIST SSDF 1.1, solange 1.2 Draft ist.
- **19-D19:** Incident Response wird über Betrieb, Risiko, Datenschutz und Kundenkommunikation integriert.
- **19-D20:** Der Demonstrator implementiert reale Autorisierung und Auditierung, obwohl Daten und externe Systeme synthetisch sind.
- **19-D21:** Mandantenübergreifende Benchmarks verwenden keine Rohkundendaten, sondern nur freigegebene aggregierte Ergebnisse.
- **19-D22:** Personenbezogene Produktivitätsmessung ist kein verstecktes Kernziel und benötigt gesonderte Governance.
- **19-D23:** Löschung wird als verifizierter Lifecycle umgesetzt, nicht als einzelner UI-Button.
- **19-D24:** Rechtliche Rollen, Meldepflichten und Aufbewahrungsgründe werden unterstützt, aber nicht autonom von der Software entschieden.

45. Begründete Annahmen

- **19-A01:** Die meisten Pilotkunden können mit Shared-Database-/RLS-Isolation starten, wenn mehrschichtige Tests und Supportkontrollen wirksam sind.
- **19-A02:** Hochregulierte Kunden verlangen später dedizierte Schlüssel-, Datenbank- oder Deploymentgrenzen.
- **19-A03:** Enterprise Federation reduziert lokales Passwort- und Lifecycle-Risiko.
- **19-A04:** Ein kombiniertes RBAC/ABAC/ReBAC-Modell ist mit einer erklärbaren Policy Engine umsetzbar.
- **19-A05:** Hashverkettete Audit Batches plus geschütztes Archiv bieten für den ersten Produktivreifegrad ausreichenden Manipulationsnachweis.
- **19-A06:** Vollständige WORM- oder HSM-Optionen werden erst für höhere Assurance-Tiers erforderlich.
- **19-A07:** Öffentliche Cloud-KMS- und Secret-Manager-Dienste erfüllen die frühen Anforderungen, sofern Region und Vertrag passen.

- **19-A08:** Die meisten Evidence-Dateien können mit marktüblichen Malware- und Content-Scannern sicher vorverarbeitet werden.
- **19-A09:** Kunden akzeptieren transparente Supportzugriffe eher als einen undurchsichtigen globalen Betreiberadmin.
- **19-A10:** Eine zentrale Data Classification Policy kann durch kundenspezifische Erweiterungen ergänzt werden.
- **19-A11:** Audit- und Logvolumen bleibt im ersten Pilot mit PostgreSQL plus Object Storage beherrschbar.
- **19-A12:** Eine vollständige SIEM-Anbindung ist für den Demonstrator nicht erforderlich; Security Events und Playbooks können intern simuliert werden.
- **19-A13:** Datenschutzrollen und Rechtsgrundlagen unterscheiden sich je Service- und Vertragsmodell und bleiben bis zur Betreiberentscheidung teilweise offen.
- **19-A14:** Synthetische Daten reichen für Security-Demos aus, wenn Cross-Tenant-, File-, Export- und Incidentfehler real abgebildet werden.
- **19-A15:** Die Agentenfirma aus Dokument 20B kann Security Reviews beschleunigen, ersetzt aber keine menschliche Freigabe kritischer Risiken.

46. Offene Fragen

- **19-Q01:** Welcher Identity Provider wird für Demo, Pilot und Produktion verbindlich?
- **19-Q02:** Werden Passkeys im ersten Piloten angeboten oder erst nach Enterprise Federation?
- **19-Q03:** Welche Session-, Idle- und Step-up-Zeiten gelten je Rolle und Datenklasse?
- **19-Q04:** Welche Policy Engine oder interne Authorization Library wird verwendet?
- **19-Q05:** Welche Basisrollen und Berechtigungen werden in der ersten Rollenmatrix final freigegeben?
- **19-Q06:** Welche Kunden benötigen dedizierte Datenbank-, Schlüssel- oder Deploymentisolation?
- **19-Q07:** Wie wird kundenseitige Genehmigung von Supportzugriff technisch und vertraglich gestaltet?
- **19-Q08:** Welche PAM-/JIT-Lösung wird für produktiven Plattformbetrieb eingesetzt?
- **19-Q09:** Welche KMS-/HSM- und Tenant-Key-Optionen werden angeboten?
- **19-Q10:** Welche konkreten Algorithmen, Mindestlängen und TLS-Profile gelten bei Implementierungsstart?
- **19-Q11:** Welcher Secret Manager und welche Rotationsmechanismen werden gewählt?
- **19-Q12:** Welche Datenklassen und Retentionfristen gelten je Betreiber- und Kundenvertrag?
- **19-Q13:** Welche Rechtsrollen übernimmt der spätere Betreiber je Service?
- **19-Q14:** Welche internationalen Datenübermittlungen und Subprozessoren sind vorgesehen?
- **19-Q15:** Welche Betroffenenrechte können direkt automatisiert und welche nur unterstützt werden?
- **19-Q16:** Welche Audit Records benötigen WORM, Signatur oder externen Timestamp?
- **19-Q17:** Welche technische Retention erhalten Security Logs, Audit Records und Evidence?
- **19-Q18:** Welche SIEM-, SOC- und Detection-Plattform wird integriert?
- **19-Q19:** Welche Malware-, CDR- und Sandboxlösung wird für Dateien genutzt?
- **19-Q20:** Welche Penetrationstest- und unabhängigen Assurance-Rhythmen gelten?
- **19-Q21:** Welche Vulnerability-SLAs werden nach Severity, Exposure und Tenantimpact zugesagt?
- **19-Q22:** Welche SBOM-, Signatur- und Artefaktprovenance-Technologie wird verwendet?
- **19-Q23:** Welche NIS2-, DORA- und nationalen Meldeplaybooks werden als Standardpaket geliefert?
- **19-Q24:** Welche Anforderungen gelten für Betriebsrat, Mitarbeiterdatenschutz und Beraterleistungskennzahlen?
- **19-Q25:** Wie werden tenantselektive Restore-, Lösch- und Legal-Hold-Fälle in unveränderbaren Backups gelöst?
- **19-Q26:** Welche Security Features müssen in einem privat entwickelten Showcase echt produktionsnah sein und welche dürfen simuliert bleiben?

47. Ideen für später

- kundenverwaltete Schlüssel und Bring Your Own Key,
- HSM-gestützte Tenant Signing Keys,
- Confidential Computing für besonders sensible Verarbeitung,
- Continuous Access Evaluation über Shared Signals/CAEP,
- Relationship-Based Access Control mit graphbasierter Policyauswertung,
- Policy-as-Code Marketplace für Branchepakete,
- verifizierbare Credentials für Auditoren und externe Experten,
- hardwaregestützte Workload Attestation,
- passwortloser Standardbetrieb mit Passkeys,
- tenantbezogene Security Data Pods,
- automatische Privacy Data Map aus Connector- und Graphmetadaten,
- differenzielle Privacy für Practice Benchmarks,
- cryptographic erasure für ausgewählte Datenklassen,
- externe Transparency Log Anchors für Audit Batches,
- Content Disarm and Reconstruction für Office/PDF-Evidence,
- sichere Offline Evidence Collection für Vor-Ort-Audits,
- Customer Security Posture API,
- automatisierte Attack-Path-Simulation gegen Berechtigungen und Twin,
- Purple-Team- und Chaos-Security-Szenarien,
- just-in-time, taskgebundene Agentenrechte,
- tenantbezogene Security Assurance Scorecards mit verifizierten Testbelegen.

48. Dokumentenabhängigkeiten

48.1 Eingehende Abhängigkeiten

- **Dokument 00:** Projektverfassung, zentrale Wahrheit und Änderungslogik.
- **Dokument 01:** Produktvision, Vertrauen und Managed-Service-Business-Case.
- **Dokument 03 und 04:** Nutzerrollen, reale Situationen und vollständige Journeys.
- **Dokument 05 und 06:** Produktmodule, UX, Rollenwelten und Zustände.
- **Dokument 07:** Objektmodell, Provenance, Historie und Graphbeziehungen.
- **Dokument 08 und 09:** ISMS-Prozesse, Risiko-, Threat-, Control- und Confidence-Logik.
- **Dokument 10:** Decision Cards, KPIs, Routen und Simulationen.
- **Dokument 11:** Work Items, Delegation, Freigaben, Kommunikation und Handover.
- **Dokument 12:** Reports, Snapshots, Exporte und Artefakte.
- **Dokument 13 bis 16:** Managed Services, Preis-/SLA-Logik, Beraterbetrieb und Kunden-Lifecycle.
- **Dokument 17:** Connectoren, Webhooks, Workflows und Automationen.

- **Dokument 18:** technische Referenzarchitektur, Tenant Isolation, Datenhaltung, Worker, Storage und Plattformbetrieb.

48.2 Ausgehende Abhängigkeiten

- **Dokument 20A:** konkretisiert KI-Datenminimierung, Prompt-/Modellschutz, Human Gates, Modellprovider, Output Assurance und AI Incident Handling.
- **Dokument 20B:** weist Product Security, Privacy, IAM, AppSec, Platform Security, QA, Audit Integrity und Incident-Agenten zu.
- **Dokument 20C:** setzt Security Gates, Repositoryschutz, Branch Policies, Secret Scanning, SBOM, Tests, Releasefreigaben, Checkpoints und Incident-Handover technisch um.

48.3 Änderungsregel

Änderungen an Identity, Basisrollen, Authorization Policy, Tenant Isolation, Supportzugriff, Break Glass, Kryptografie, Key Management, Datenklassifikation, Retention, Audit Record, Logging, Datei- oder Exportpipeline, Secure-SDLC-Gates, Incident Response oder Datenschutzrollen benötigen Security-/Privacy-Impactanalyse, ADR oder Policy Decision Record, Tests und Freigabe. Änderungen dürfen bestehende Audit- oder Entscheidungsnachweise nicht rückwirkend umdeuten.

49. Öffentliche Referenzquellen

Die folgenden offiziellen Quellen dienen als Sicherheits-, Datenschutz- und Plausibilitätsanker. Sie ersetzen keine kundenspezifische Rechts-, Audit- oder Zertifizierungsbewertung.

- **S1 – Datenschutz-Grundverordnung, Verordnung (EU) 2016/679:** Grundsätze, Privacy by Design/Default, Sicherheit der Verarbeitung und Datenschutzverletzungen. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- **S2 – NIS-2-Richtlinie, Richtlinie (EU) 2022/2555:** Cybersecurity-Risikomanagement, Supply Chain, Zugriff, Kryptografie, Wirksamkeit und Incidentpflichten. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- **S3 – DORA, Verordnung (EU) 2022/2554:** dokumentierter IKT-Risikomanagementrahmen, Schutz, Monitoring, Resilienz und Drittparteienabhängigkeiten. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj>
- **S4 – Delegierte Verordnung (EU) 2024/1774:** technische Standards zu IKT-Risikomanagementtools, Methoden, Prozessen und Policies unter DORA. https://eur-lex.europa.eu/eli/reg_del/2024/1774/oj
- **S5 – NIST SP 800-53 Rev. 5, Release 5.2.0:** Security- und Privacy-Control-Familien einschließlich Access, Audit, Incident, Supply Chain und PII Processing. <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- **S6 – NIST SP 800-207 Zero Trust Architecture:** ressourcen-, identitäts- und policybezogene Zugriffsentscheidungen ohne implizites Netzwerkvertrauen. <https://csrc.nist.gov/pubs/sp/800/207/final>
- **S7 – NIST SP 800-207A:** Zero-Trust-Zugriffsmuster für cloudnative Anwendungen und Workload Identities. <https://csrc.nist.gov/pubs/sp/800/207/a/final>
- **S8 – NIST SP 800-218 SSDF 1.1:** stabile Secure-Software-Development-Praktiken. <https://csrc.nist.gov/pubs/sp/800/218/final>
- **S9 – NIST SP 800-61 Rev. 3:** Incident Response als Bestandteil des Cybersecurity Risk Management. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- **S10 – OWASP ASVS 5.0.0:** aktuelle Verifikationsbasis für technische Webanwendungssicherheitskontrollen. <https://owasp.org/www-project-application-security-verification-standard/>
- **S11 – OWASP Top 10:2025:** aktuelle Awareness-Kategorien für Webanwendungsrisiken. <https://owasp.org/Top10/2025/>
- **S12 – BSI OPS.1.1.5 Protokollierung:** sichere Erhebung, Speicherung, Auswertung und Entsorgung sicherheitsrelevanter Protokolldaten. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/IT-GS-Kompodium_Einzel_PDFs_2022/04_OPS_Betrieb/OPS_1_1_5_Protokollierung_Edition_2022.html
- **S13 – BSI CON.8 Software-Entwicklung:** Sicherheitsanforderungen für Vorbereitung und Durchführung eigener Softwareentwicklung. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/IT-GS-Kompodium_Einzel_PDFs_2023/03_CON_Konzepte_und_Vorgehensweisen/CON_8_Software_Entwicklung_Edition_2023.html
- **S14 – BSI Mindeststandard externe Cloud-Dienste:** Sicherheits- und Bewertungsanforderungen für Cloud-Nutzung. <https://www.bsi.bund.de/dok/MST-Cloud>
- **S15 – BSI Mindeststandard TLS:** aktuelle Mindestanforderungen und Referenz zu sicheren TLS-Konfigurationen. <https://www.bsi.bund.de/EN/Themen/Oeffentliche-Verwaltung/Mindeststandards/TLS-Protokoll/TLS-Protokoll.html>
- **S16 – RFC 9700, OAuth 2.0 Security Best Current Practice:** aktuelle Sicherheitsanforderungen für OAuth-Flows, Tokens und Clients. <https://www.rfc-editor.org/info/rfc9700>
- **S17 – OpenID Shared Signals und CAEP:** standardisierte Security Events und kontinuierliche Zugriffsneubewertung als spätere Erweiterungsoption. <https://openid.net/wg/sharedsignals/specifications/>

50. Änderungsprotokoll

Version	Datum	Änderung	Status
1.0	22.07.2026	Erstfassung für Security Architecture, Threat Model, Identity, RBAC/ABAC/ReBAC, Tenant Isolation, privilegierte und Supportzugriffe, Kryptografie, Datenschutz-Lifecycle, Retention, Audit Records, Logging, File/Export Security, Secure SDLC, Supply Chain, Vulnerability Management, Incident Response, Demo und Assurance	Erstellt